ISEP

Segurança de Sistemas e Informação (SEGSI)
PL10
Joaquim Filipe Peixoto dos Santos (**JPE**)
Pedro Filipe Cruz Pinto (**PFP**)
Dílio Adalberto da Rocha Ribeiro (**DAR**)
Daniela Alexandra Pires Pinto (**DPI**)
{ @isep.ipp.pt }

Exercise 1: DNS

To ensure that you keep your assets private in a somewhat segmented environment, you need to ensure that name resolutions do not fall prey to lingering eyes. In this exercise, we aim to show how can someone divide such domains and create the necessary DNS Policies to ensure that you have some control over DNS.

1. Define two DNS Zones, one internal, and one external. I.E. SEGSILABXX.pt and SESGSILAB.local. Install Unbound[1] and create those two zones.
2. Create two subzones ”eng”, and ”testing” within the internal zone, rendering to eng.SESGSILAB.local and testing.SESGSILAB.local[2].
3. Create policies such that only one IP can resolve the internal network and other IP can resolve the external part (Use different VMs if you see fit).
4. Configure unbound such that it receives internal DNS resolution queries and forwards them through DNS over TLS. What do you gain here from a security engineering perspective[3]?
5. What is DNSSEC?
6. Why should we block internal assets from resolving the External DNS zone?
7. Configure unbound to only allow resolutions of google.com[4].
8. Configure unbound to audit every resolution. Explore the theme of Data Exfiltration by DNS and Data Leakage Prevention (DLP)[5].

[1] https://nlnetlabs.nl/projects/unbound/about/
[2] https://unbound.docs.nlnetlabs.nl/en/latest/getting-started/installation.html
[3] https://wiki.archlinux.org/title/Unbound
[4] https://unbound.docs.nlnetlabs.nl/en/latest/topics/filtering/rpz.html
[5] https://snippets.khromov.se/enable-logging-of-dns-queries-in-unbound-dns-resolver/

Exercise 2: Reverse Proxies/Load Balancers

Now that you have different zones you need to bridge between the Internet and your internal services. A DMZ is a network zone where we expose assets. Exposing internal assets is a bad practice. Creating these zones and deploying Reverse proxies help us gain visibility and control of what we expose in our infrastructure.

1. Do the practical part from steps 1 to 4 from Exercise 1.
2. Install HAProxy[6] on a machine.
3. Configure such that it accepts an external DNS name and redirects traffic to an internal DNS set.
4. Choose the load-balancing strategy. Specify what is the best strategy.
5. If you want to maintain a machine, you need to stop taking it out of commission. What happens to the user sessions?
6. How would you design logging such that you capture attack attempts?
7. (Optional) Create the necessary rules in Wazuh to detect login bruteforce.

[6] https://www.haproxy.org/